KARTIKA: Product Requirements Document

Kepatuhan Audit Risiko & Teknologi Informasi Keamanan Aplikasi

1. Ringkasan Eksekutif

KARTIKA adalah perangkat bantu audit otomatis yang beroperasi di irisan antara keamanan siber operasional dan kepatuhan regulasi. Produk ini memecahkan masalah inefisiensi dan komunikasi yang terisolasi (*silo*) antara tim IT Security dan tim Legal/Compliance. Sistem ini bekerja dengan memindai kerentanan teknis (OWASP Top 10) serta eksposur Data Pribadi Spesifik/Umum (PII), lalu menerjemahkannya secara instan ke dalam bahasa hukum (UU PDP dan standar BSSN) melalui dokumen *Compliance Readiness Report*.

2. Sasaran Pengguna (User Personas)

- **IT Security / Auditor Siber:** Membutuhkan alat otomatis untuk memindai aplikasi web dan basis data secara efisien tanpa harus mengonfigurasi skrip pengujian manual berulang kali.
- **Compliance & Legal Officer:** Membutuhkan dasbor dan laporan yang menerjemahkan temuan teknis (seperti *SQL Injection*) ke dalam konteks pelanggaran pasal spesifik beserta risiko hukumnya.
- **Komandan Satuan / C-Level:** Membutuhkan laporan ringkas (*executive summary*) terkait postur keamanan siber instansi untuk pengambilan keputusan strategis dan alokasi sumber daya.

3. Kebutuhan Fungsional (Functional Requirements)

- **Manajemen Target Audit:** Registrasi URL aplikasi web dan kredensial koneksi basis data (MySQL, PostgreSQL) yang akan diuji secara aman.
- **Pemindai Kerentanan (DAST Engine):** Eksekusi *Dynamic Application Security Testing* untuk mengidentifikasi celah keamanan berbasis OWASP Top 10.
- **Detektor Eksposur PII:** Modul agen pemindai yang menganalisis struktur dan sampel isi basis data guna mendeteksi keberadaan entitas PII (NIK, nama, rekam medis) dan memverifikasi penerapan algoritma enkripsi/hashing.
- **Mesin Pemetaan Regulasi:** Algoritma pemetaan referensi silang (*cross-reference*) otomatis antara temuan kerentanan sistem dengan pasal-pasal kewajiban pada UU Pelindungan Data Pribadi dan pedoman BSSN.
- **Generator Laporan Kepatuhan:** Ekspor dokumen instan (PDF) yang memuat Ringkasan Eksekutif, Temuan Teknis, Dampak Hukum, serta Langkah Remediasi.

4. Kebutuhan Non-Fungsional & Keamanan

- **Keamanan Kredensial:** Seluruh data koneksi target (connection strings) dan hasil temuan kritis dienkripsi menggunakan standar AES-256 pada basis data internal KARTIKA.
- **Performa Pemindaian:** Proses audit untuk aplikasi skala menengah (hingga 500 titik akhir / 5GB data) memiliki target waktu penyelesaian maksimal 3 jam operasional.
- **Jejak Audit (Audit Trail):** Pencatatan log aktivitas pengguna secara komprehensif yang tidak dapat diubah (immutable) untuk menjamin akuntabilitas akses.

5. Desain Entity-Relationship Diagram (ERD)

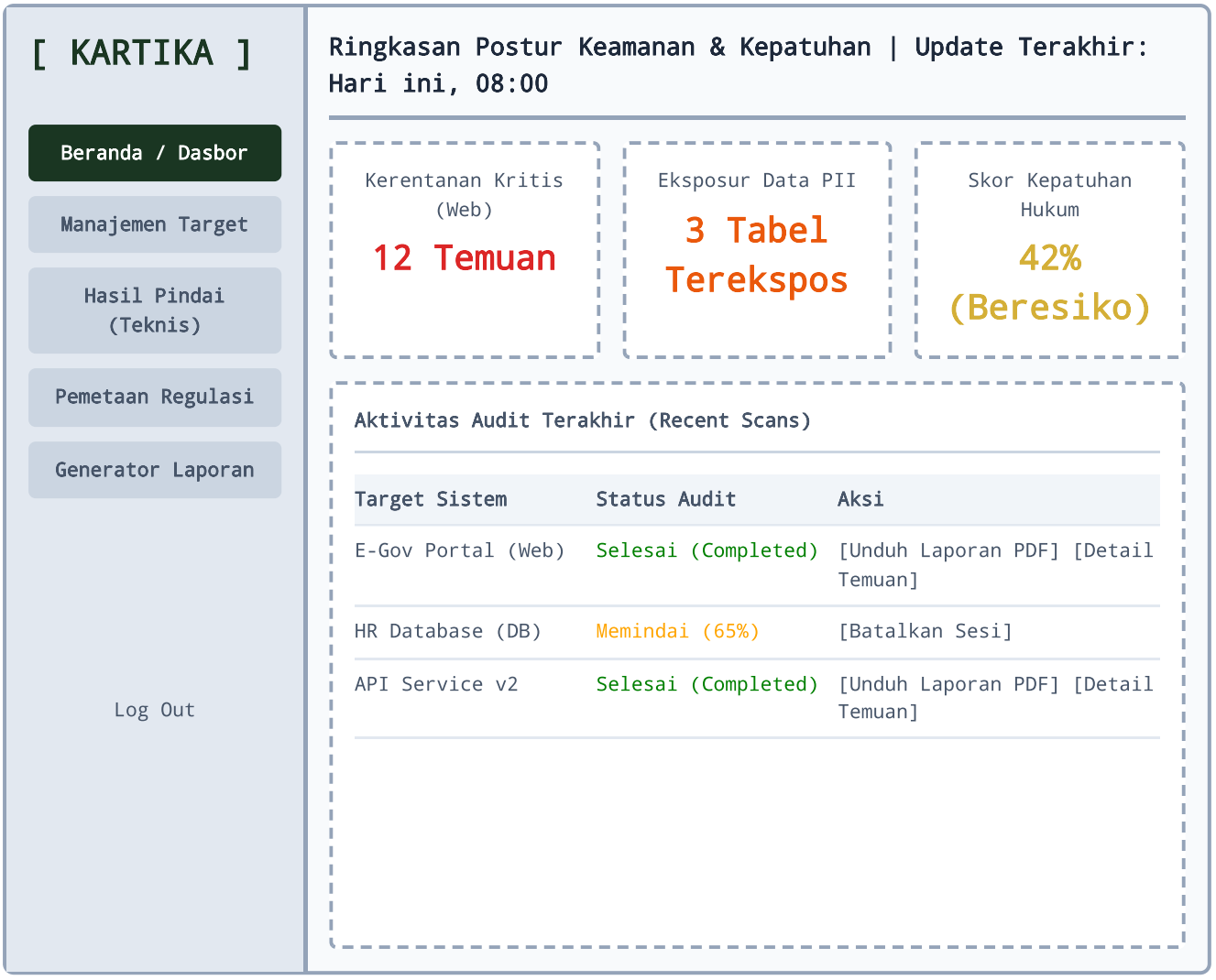
Arsitektur basis data KARTIKA memisahkan entitas operasional (target dan hasil pindai) dengan referensi statis (undang-undang), yang dihubungkan melalui tabel relasional pemetaan kepatuhan.

Nama Entitas	Atribut Utama (Primary Key & Foreign Key)	Deskripsi Fungsional
Pengguna	`id_pengguna` (PK)	Menyimpan profil otentikasi (Admin, Security, Legal).
Target_Sistem	`id_target` (PK) `id_pengguna` (FK)	Mencatat URL Web atau kredensial Database (terenkripsi) yang menjadi target audit keamanan.
Sesi_Audit	`id_sesi` (PK) `id_target` (FK)	Merekam waktu mulai, selesai, dan status (Running/Completed) dari setiap tugas pemindaian.
Temuan_Teknis	`id_temuan` (PK) `id_sesi` (FK)	Menyimpan detail kerentanan (OWASP) atau eksposur data (PII terekspos tanpa enkripsi).
Regulasi_Hukum	`id_regulasi` (PK)	Katalog referensi pasal UU PDP dan regulasi siber nasional beserta deskripsi sanksi administrasinya.
Pemetaan_Kepatuhan	`id_pemetaan` (PK) `id_temuan` (FK) `id_regulasi` (FK)	Tabel *Junction* (N:M). Memetakan kerentanan teknis spesifik terhadap pelanggaran pasal hukum tertentu.
Laporan_Kepatuhan	`id_laporan` (PK) `id_sesi` (FK)	Menyimpan rekam jejak dokumen PDF (Compliance Report) yang telah di-generate oleh sistem.

6. Rancangan Antarmuka Pengguna (Wireframe)

Antarmuka KARTIKA didesain dengan pendekatan dasbor taktis (*tactical dashboard*). Fokus utama adalah visibilitas cepat terhadap tingkat risiko dan akses instan ke pembuatan laporan kepatuhan.

Wireframe: Dasbor Utama (Executive View)



Penjelasan Alur: Pengguna masuk ke Dasbor untuk melihat metrik kritis. Melalui menu "Hasil Pindai", auditor dapat memverifikasi kerentanan secara mendalam (misal: *Injection*). Sistem di balik layar (tabel *Pemetaan_Kepatuhan*) akan otomatis menautkan temuan tersebut ke pasal kegagalan enkripsi data di UU PDP. Legal Officer kemudian dapat mengeklik "Unduh Laporan PDF" untuk mencetak dokumen kepatuhan formal.